Seguridad y respaldos

Entrega 8 · Sistema de registro y gestión del Mundial de Fútbol · 9 de noviembre de 2026

Alcance y supuestos

La base `MundialFutbol` guarda datos personales de jugadores, integrantes de cuerpos técnicos y árbitros. Se cifran con AES-256 el nombre, el apellido y la fecha de nacimiento de `Torneo.JUGADOR`, `Torneo.PERSONA_CUERPO_TECNICO` y `Arbitraje.ARBITRO`, y se limita el acceso con roles de base de datos. El cifrado es por columna (`ENCRYPTBYKEY`), así que funciona en cualquier edición de SQL Server, incluida Express. El cifrado y los roles se implementan con SP.

El cifrado no reemplaza la autorización: un usuario con permiso para leer un reporte ve los nombres descifrados. Por eso los roles no tienen `SELECT` ni DML directo sobre las tablas: los cambios se hacen con SP y las consultas con el esquema `Reportes`. La conexión cifrada en tránsito y el firewall se configuran en la instancia y el sistema operativo, fuera de estos scripts.

Cifrado de los datos personales

Claves

La clave maestra de la base protege al certificado `CertDatosPersonales`, y el certificado protege a la clave simétrica `ClaveDatosPersonales` (AES-256), que es la que cifra los datos. La clave maestra queda protegida por una contraseña y por la clave maestra del servicio de la instancia.

Cómo se aplica

El cifrado es un script de modificación sobre la base ya cargada. `38_Ejecutar_Cifrado.sql` se ejecuta después de las importaciones y corre, en orden:

Script	Qué hace
`41_SP_Cifrado.sql`	`Seguridad.usp_ConfigurarCifrado` crea la clave maestra, el certificado y la clave simétrica si no existen. También crea los SP que abren y cierran la clave y las funciones que cifran.
`42_Cifrado_Tablas.sql`	`Seguridad.usp_CifrarDatosPersonales` cambia las nueve columnas a `VARBINARY`, cifra los datos existentes y verifica cada fila antes de borrar la columna original, todo en una transacción. Después crea las vistas descifradas.
`43_Cifrado_Torneo.sql`	Actualiza los SP de `Torneo` que guardan o buscan personas (ABM, convocatorias, reemplazos, importaciones).
`44_Cifrado_DesarrolloYArbitraje.sql`	Lo mismo para `DesarrolloPartido` y `Arbitraje`.
`45_Cifrado_Reportes.sql`	Actualiza las vistas y los SP de `Reportes` que muestran nombres.

La contraseña de la clave maestra se pasa con `:setvar ClaveMaestra` en el runner. El valor del repositorio es de ejemplo y hay que cambiarlo antes de ejecutar. `38` se puede ejecutar más de una vez: lo que ya está cifrado no se vuelve a cifrar, y las claves no se recrean, porque recrearlas dejaría ilegibles los datos cifrados. Después de cifrar se puede seguir importando: los SP de importación cifran lo que guardan.

Cómo se guardan y se leen los datos

- **Al guardar**, los SP abren la clave con `Seguridad.usp_AbrirClave`, cifran con `Seguridad.fn_CifrarTexto` y `Seguridad.fn_CifrarFecha`, y la cierran con `Seguridad.usp_CerrarClave`, también si hay un error. Si un SP llama a otro, el de adentro no cierra la clave que abrió el de afuera. Con la clave cerrada el cifrado da `NULL`, y como nombre y apellido no admiten `NULL`, el `INSERT` falla en lugar de guardar un dato vacío.
- **Al leer**, los SP y las vistas usan `Seguridad.vw_Jugador`, `Seguridad.vw_PersonaCuerpoTecnico` y `Seguridad.vw_Arbitro`. Tienen las mismas columnas que su tabla, con los datos descifrados por `DECRYPTBYKEYAUTOCERT`. Una vista se integra en la consulta que la usa, así que la clave se abre una sola vez para todas las filas. Una función de descifrado se puede ejecutar fila por fila: en el reporte de suspensiones activas tardó 4,2 segundos, contra 63 ms con la vista.
- Las vistas de `Reportes` devuelven las mismas columnas y los mismos tipos que antes del cifrado, así que el tablero de Power BI no cambia.

Consecuencias en el diseño

- `ENCRYPTBYKEY` da un resultado distinto cada vez, aun para el mismo texto. Por eso no se puede indexar ni comparar el dato cifrado, y se quitaron las restricciones `UNIQUE` que incluían esas columnas (en `JUGADOR` y `ARBITRO`). Los SP controlan los duplicados comparando sobre las vistas descifradas.
- Los tests de entregas anteriores que buscan personas por nombre directamente en las tablas dejan de encontrarlas: 53, 54, 55, 57, 60, 61, 64 y 73. Como su limpieza también busca por nombre, dejan datos de prueba. Los tests 56, 62, 63, 66 y 80 muestran los datos cifrados en lugar de los nombres. Las consultas de evidencia de las secciones 9 y 10 de `32_Ejecutar_DatosComplementarios.sql` también leen las tablas y fallan sobre la base cifrada; la carga de datos de ese script funciona.

Resguardo del certificado

Si se pierde el certificado, los datos cifrados no se pueden recuperar. Después de la primera ejecución de `38`, el DBA respalda el certificado con su clave privada fuera del servidor, con acceso restringido, y nunca en el repositorio:

```
BACKUP CERTIFICATE CertDatosPersonales
    TO FILE = N'<ruta segura fuera del servidor>\CertDatosPersonales.cer'
    WITH PRIVATE KEY (
        FILE = N'<ruta segura fuera del servidor>\CertDatosPersonales.pvk',
        ENCRYPTION BY PASSWORD = N'<contraseña robusta>'
    );
```

La contraseña de la clave maestra se guarda con el mismo cuidado.

Roles y permisos

Rol	Puede	No puede	Datos personales
`rol_AdministradorOperativo`	Ejecutar los ABM y los SP de negocio de todos los módulos, incluidas las importaciones desde tablas de staging; leer y ejecutar `Reportes`.	Leer o modificar tablas directamente; ejecutar los loaders que leen archivos del servidor o consumen APIs; administrar el servidor.	Cifra y descifra (da de alta y modifica personas).

Rol	Puede	No puede	Datos personales
`rol_CargadorResultados`	Iniciar y finalizar partidos; registrar formaciones, cambios, goles y amonestaciones mediante SP.	Gestionar publicidad, ejecutar reportes o leer y modificar tablas directamente.	Descifra (los SP buscan a los jugadores de la formación y de las tarjetas).
`rol_GestorPublicidad`	Ejecutar el ABM y la asignación de publicidad; consultar la ocupación y los ingresos publicitarios.	Consultar reportes deportivos o leer y modificar tablas directamente.	Ninguno: no puede descifrar.
`rol_ConsultaReportes`	Leer las vistas y ejecutar los SP del esquema `Reportes`.	Ejecutar operaciones de negocio, importaciones o modificaciones.	Descifra (los reportes muestran nombres).

`40_Seguridad.sql` crea el esquema `Seguridad` y el SP `Seguridad.usp_ConfigurarRoles`. El SP crea los roles y los usuarios de prueba, y otorga los permisos por esquema o por procedimiento. Deniega `SELECT`, `INSERT`, `UPDATE` y `DELETE` directos en los cinco esquemas de datos, y `SELECT` y `EXECUTE` sobre `Seguridad`. Los objetos pertenecen a `dbo`, así que el encadenamiento de propiedad deja que los SP y las vistas usen las tablas sin dar esos permisos a quien los invoca. `38` vuelve a ejecutar el SP después de crear las claves, para dar los permisos sobre la clave.

Permiso sobre la clave

El encadenamiento de propiedad no alcanza a las claves ni a los certificados. SQL Server comprueba el permiso del usuario que consulta, aunque el descifrado ocurra dentro de una vista; sin ese permiso, el dato descifrado sale `NULL`. Por eso los tres roles que trabajan con datos personales reciben:

- `VIEW DEFINITION` sobre `ClaveDatosPersonales`, necesario para cifrar y descifrar.
- `CONTROL` sobre `CertDatosPersonales`, necesario para descifrar con el certificado.
- `DENY ALTER` y `DENY TAKE OWNERSHIP` sobre el certificado. Así no pueden quitarle la clave privada (lo que dejaría los datos irrecuperables) ni apropiárselo. Tampoco pueden borrar la clave ni el certificado.

El gestor de publicidad recibe `DENY` sobre la clave y el certificado. Los roles no pueden leer los datos cifrados de las tablas, así que solo descifran lo que les muestran los SP y las vistas que tienen permitidos.

Usuarios

Los usuarios `usr_test_*` son principals `WITHOUT LOGIN`; solo sirven para impersonación en las pruebas. En el despliegue real, el DBA crea o mapea logins de Windows o de aplicación y los agrega al rol que corresponde. No se deben agregar usuarios de aplicación a `db_owner`, `db_datareader` ni `db_datawriter`.

Las importaciones que leen archivos del servidor (`BULK INSERT`, `OPENROWSET(BULK)`) o consumen APIs (OLE Automation) quedan reservadas a una sesión de DBA. Requieren permisos de servidor que no se dan a los roles de aplicación: `ADMINISTER BULK OPERATIONS` y `sysadmin`.

Política de respaldos

El objetivo de punto de recuperación (RPO) se ajusta al volumen de escrituras, que es mucho mayor los días de partido:

Situación	Completo	Diferencial	Log de transacciones	RPO máximo
Días con partidos	Diario, 01:00	Cada 6 horas	Cada 5 minutos	5 minutos

Situación	Completo	Diferencial	Log de transacciones	RPO máximo
Días sin partidos	Diario, 01:00	Cada 12 horas	Cada 15 minutos	15 minutos

La base usa recuperación `FULL`, así que los backups del log se ejecutan de forma regular. Si se interrumpe esa cadena, no se mantiene el RPO hasta hacer un nuevo backup completo y restablecer la secuencia.

- Guardar los backups en un volumen distinto del de los archivos `.mdf` y `.ldf`. Copiar cada backup a un segundo medio y a una ubicación fuera del servidor (regla 3-2-1), y restringir el acceso a los operadores de backup.
- Usar `CHECKSUM` en cada backup, y `COMPRESSION` en la plataforma del TP4 (SQL Server 2022 Standard); Express no comprime backups. `RESTORE VERIFYONLY` comprueba que el backup se pueda leer. Además, ejecutar `DBCC CHECKDB` cada semana y restaurar una copia en un servidor aislado al menos una vez por mes.
- Retener los completos, diferenciales y logs durante 35 días. Borrar una cadena solo cuando ya no haga falta para llegar a un punto de restauración dentro de ese plazo.
- Para recuperar a un instante: restaurar el último completo con `NORECOVERY`, el diferencial más reciente posterior a ese completo con `NORECOVERY` y los backups de log en orden. Usar `STOPAT` si se necesita un instante puntual, y terminar con `RECOVERY`.
- Las columnas cifradas siguen cifradas en los backups, y la clave maestra, el certificado y la clave simétrica viajan con la base. Al restaurar en otra instancia, la clave maestra no se abre sola: hay que abrirla con su contraseña (`OPEN MASTER KEY DECRYPTION BY PASSWORD`) y volver a protegerla con la clave maestra del servicio de esa instancia (`ALTER MASTER KEY ADD ENCRYPTION BY SERVICE MASTER KEY`). Por eso la contraseña de la clave maestra se guarda junto con el backup del certificado.
- Registrar el resultado, la duración, el tamaño y la ubicación de cada backup. La restauración mensual de prueba sirve para medir el RTO real y para detectar fallas que un backup que nunca se restauró no muestra.

Orden de ejecución y pruebas

1. `37_Ejecutar_PrepararBase.sql`: recrea la base, crea los objetos y los roles (`40`).
2. Las importaciones: `26`, `29`, el scraping, `31`, `32` y `33`.
3. `38_Ejecutar_Cifrado.sql`: cifra los datos personales.
4. Los tests de seguridad.

Hay un script de test por usuario: `81_Test_Rol_Administrador.sql`, `82_Test_Rol_CargadorResultados.sql`, `83_Test_Rol_GestorPublicidad.sql` y `84_Test_Rol_ConsultaReportes.sql`. Cada uno tiene dos partes:

1. Los permisos declarados del usuario (`HAS_PERMS_BY_NAME`), incluidos los de la clave y el certificado.
2. La ejecución real: cada operación se ejecuta como el usuario (`EXECUTE AS USER`) dentro de una transacción que se deshace, así que no queda nada. El resultado dice si la operación quedó permitida o denegada, y, cuando lee datos personales, si el usuario los ve descifrados o como `NULL`.

`85_Test_Cifrado.sql` comprueba:

- que existan las claves y que las nueve columnas estén cifradas;
- que no queden restricciones `UNIQUE` sobre ellas;
- que todas las filas se puedan descifrar y que lo guardado no sea el texto original;
- que el mismo texto cifrado dos veces dé resultados distintos;
- que sin abrir la clave no se pueda guardar una persona;
- que un alta por SP se lea descifrada y que el SP rechace el duplicado;
- que no queden claves abiertas.

Todos los tests terminan con error si algún control no da lo esperado.